

Capítulo
04

La gestión del riesgo

Objetivos
Comprender, describir y evaluar el proceso de gestión del riesgo.

Conceptos
Definición de la gestión del riesgo, el análisis/evaluación de riesgos y la aceptación, el procesamiento y la comunicación de los riesgos.

Gestión de Riesgo

Definiciones

Preguntas – Gestión del riesgo

- »¿Qué es riesgo para usted?
- »¿Qué entiende usted por gestión del riesgo?

Riesgo de seguridad es una combinación de **amenazas, vulnerabilidades e impactos**. Las **amenazas** son eventos que aprovechan las **vulnerabilidades** (debilidades) y pueden causar daños. El **impacto es** el resultado de una vulnerabilidad al ser explotada por una amenaza.

En cuanto a la gestión del riesgo, algunas definiciones se consideran importantes y se presentan a continuación:

- » La gestión del riesgo incluye todas las medidas adoptadas para controlar los riesgos en una organización, incluyendo el análisis/ evaluación, el tratamiento, la aceptación y la comunicación de los riesgos.
- » El análisis de riesgos identifica y estima los riesgos, teniendo en cuenta el uso sistemático de la información. Abarca el análisis de las amenazas, vulnerabilidades e impactos y se considera el punto clave de la política de seguridad de la información de una organización.
- » La evaluación del riesgo compara el riesgo estimado en el análisis con los criterios predefinidos con el fin de identificar la importancia de cada riesgo para la organización.
- » Aceptación de riesgos incluye la identificación del nivel aceptable de riesgos para una organización en función de sus necesidades específicas de negocio y seguridad.
- » El tratamiento del riesgo corresponde a la selección y la aplicación de medidas para modificar un determinado riesgo.

La comunicación de riesgos involucra iniciativas para mostrar los riesgos a los empleados, directivos y terceros (estos últimos, cuando sea apropiado y necesario).

Temas Claves

Para llevar a cabo una gestión eficaz del riesgo, es necesario identificar inicialmente, las amenazas y los impactos, la probabilidad de la materialización de las amenazas y riesgos potenciales. Se recomienda clasificar los riesgos según los criterios: nivel de importancia, gravedad de las pérdidas y costos involucrados en la prevención o recuperación de desastres.

Si el costo para evitar una amenaza es mayor que su daño potencial, es aconsejable tener en cuenta otras medidas. Las decisiones deben ser tomadas teniendo en cuenta la importancia que tiene para la continuidad del negocio de la organización el activo amenazado.

Tenga en cuenta que el análisis de las amenazas y vulnerabilidades busca identificar la probabilidad de ocurrencia de cada evento adverso y las consecuencias de los daños, mientras que el análisis de impacto debería identificar los recursos críticos para la organización; es decir, los que más sufren con los daños.

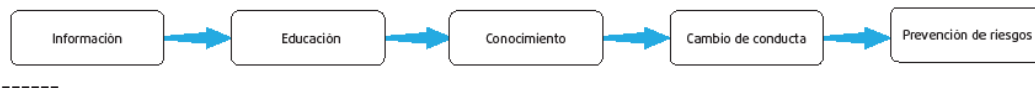
Dado que es muy difícil definir con precisión la probabilidad de que una amenaza ocurra y los respectivos daños causados, se recomienda establecer una lista de amenazas potenciales, de los recursos afectados, de los requisitos de seguridad afectados y el grado de impacto (por ejemplo, muy alto, alto, moderado, bajo y muy bajo).

La gestión del riesgo

La gestión del riesgo debe considerar los siguientes tres niveles de aplicación: tecnologías, procesos y personas. La tecnología garantiza los ajustes técnicos necesarios para el tratamiento adecuado de los riesgos; los procesos aseguran que las actividades que componen la gestión de los riesgos sean consideradas de forma sistemática, y, por último, las personas, de modo que los empleados y los gerentes identifiquen sus responsabilidades, conozcan los riesgos y puedan ayudar a su reducción y control. Instrumentos como la política de seguridad y un código de conducta se recomiendan en su contexto.

En cuanto a las medidas de seguridad, se recomienda atención a las siguientes categorías: preventivas, de carácter estructural (por ejemplo, una política formal para el control de acceso lógico); correctivas, como una emergencia (planes de contingencia, por ejemplo), e ilustrativas, con carácter educativo (entrenamientos, folletos, conferencias, etc.).

En particular, recuerde que la orientación y la información son esenciales para la reducción de riesgos. Por lo tanto tenga en cuenta la importancia del siguiente flujo de gestión del riesgo: información - conocimiento - cambio de conducta - educación - prevención de los riesgos.



Ejercicio de refuerzo - gestión del riesgo

- » ¿Cuáles son los tres niveles a tener en cuenta en la gestión del riesgo?

Análisis y evaluación de riesgos

En esta sección, se presentan los aspectos relevantes para el análisis/ evaluación de los riesgos en las organizaciones. En particular, se presentarán algunas clasificaciones para análisis de impacto, definición de probabilidades y cálculos de riesgo.

Identifica, califica/cuantifica y prioriza los riesgos de seguridad de la información.

Es esencial para:

- » Gestión del riesgo.
- » Proposición de medidas de seguridad apropiadas.

Consideraciones:

- » Deben ser sistemáticas.
- » Deben utilizar métodos concretos.
- » Se deben realizar periódicamente.

El análisis/evaluación de riesgos consiste en identificar, cuantificar y calificar los riesgos de seguridad de la información, con base en los objetivos de la organización. Incluye también la priorización de los riesgos, teniendo en cuenta los criterios de riesgo aceptable. Es una actividad que indica la forma de garantizar una gestión adecuada de la información sobre riesgos de seguridad y un conjunto adecuado de medidas de seguridad de la organización en cuestión.

Algunos aspectos de análisis / evaluación de riesgos que deben ser contemplados son:

- » Deben ser llevados a cabo de manera sistemática con el fin de identificar los riesgos (análisis) y calificar el riesgo (evaluación). El análisis de riesgo mide las amenazas, vulnerabilidades, impactos y actividades en un ambiente determinado con el fin de orientar la adopción de las medidas adecuadas al negocio y a los requisitos de seguridad de la organización.
- » Debe utilizar métodos específicos para permitir la comparación entre los resultados obtenidos y su reproducción.
- » Debe realizarse periódicamente o cuando los requisitos de seguridad, activos, vulnerabilidades y / o los objetivos de negocio sufren algún cambio.

Analizando los riesgos

El análisis de riesgo debe considerar los daños probables al negocio resultantes de fallas de seguridad; la probabilidad de que las fallas ocurran frente a las vulnerabilidades y amenazas existentes; y las medidas de seguridad implementadas (si es aplicable) para que al final, se recopilen los datos necesarios para la adecuada gestión del riesgo.

Por lo tanto, algunas preguntas deben ser contestadas:

- » ¿Qué hay que proteger?
- » ¿Cuáles son las vulnerabilidades y amenazas?
- » ¿Cómo analizar?

La respuesta a estas preguntas es esencial para la ejecución y generación de resultados en el análisis de riesgos.

Que hay que proteger

En esta etapa, se deben considerar todos los activos involucrados en el alcance del SGSI de la organización, especialmente los directamente relacionados con los objetivos del negocio. Por lo tanto, se trata de una fase que no puede ser subjetiva, es decir, se recomienda hacer un inventario cuidadoso de los activos, teniendo en cuenta parámetros y categorías de selección, por ejemplo.

En particular, se deben examinar primero las amenazas y vulnerabilidades de los activos a ser protegidos, de modo que sean considerados todos los eventos adversos que tal vez pueden explotar las debilidades de seguridad de la organización, causando daños.

Hardware, software, datos, personas, documentos, sistemas de información, contratos, entre otros, son ejemplos de activos considerados cruciales para el negocio de la organización.

Repaso de Conceptos

» Cite ejemplos de activos críticos en su organización.

Vulnerabilidades y amenazas

Después de identificar los activos que deben ser protegidos en la organización, se deben considerar las probabilidades de cada activo de ser vulnerable a las amenazas. Para ello, hay que prestar atención a la información que pueda quedar comprometida, creando listas de prioridades, por ejemplo; y los servicios de seguridad que puedan verse comprometidos, tal como la confidencialidad, integridad y disponibilidad.

Ejemplos de amenazas típicas:

- » Desastres naturales.
- » Falta de suministro de energía eléctrica.
- » Robo/estafa
- » Amenazas programadas.
- » Fallas de hardware.
- » Fallas de software.
- » Errores humanos.

A continuación se presentan algunas de las amenazas típicas en entornos de TI:

- » Los desastres naturales que afectan a la instalación física de la organización. Durante el desastre, los controles de acceso físico pueden verse comprometidos y algunos recursos con información sensible se pueden violar con facilidad.
- » Las fallas en el suministro eléctrico, que afectan a la parte de hardware de la organización. Con el hardware dañado, los servicios no estén disponibles.
- » Amenazas programadas tales como virus y bombas lógicas que afectan software. Por lo tanto, los códigos no autorizados pueden revelar la información confidencial al mundo exterior, tal como contraseñas.
- » Las fallas de hardware. De este modo, la máquina comprometida puede ser enviada a mantenimiento sin el previo cuidado de borrar la información confidencial contenida en los mismos.
- » Las fallas de software, corrompiendo los datos.
- » Los errores humanos que afectan a cualquier sistema de la organización, permitiendo así la

revelación de información confidencial; por ejemplo, imprimir información confidencial en una impresora pública.

El análisis de riesgos debe medir las amenazas, las vulnerabilidades y los impactos de modo que el resultado pueda servir como guía para la adopción de medidas de seguridad adecuadas a los requisitos de negocio de la organización, teniendo en cuenta, por lo tanto, costos asociados, nivel de protección requerido por los activos y facilidad de uso.

En particular, se puede considerar el análisis de riesgos en términos cualitativos, con el fin de cumplir con los requerimientos del negocio, o en términos cuantitativos, con el fin de asegurar que los costos de las medidas preventivas, correctivas e ilustrativas no superen el valor del activo en cuestión, en lo que se refiere al patrimonio de la organización y también a la continuidad del negocio.

Evaluación de Probabilidad e impacto

Al evaluar los riesgos se busca una base que sirve para fines de comparación, por ejemplo, el análisis y la evaluación de riesgos realizada en temporadas anteriores. El conocimiento previo de los impactos y las probabilidades de riesgo siempre es relevante para una evaluación adecuada y completa.

Por otro lado, hay básicamente dos formas de realizar la evaluación del riesgo:

» **Cualitativo:** evaluación de riesgos a través de la estimación cualitativa es la que utiliza calificadores y atributos descriptivos para evaluar. No se asignan valores financieros. Se considera muy subjetiva. Ejemplo: Alto, Medio, Bajo, Muy Bajo.

» **Cuantitativo:** evaluación de riesgos a través de una estimación cuantitativa es aquella que utiliza valores numéricos financieros para cada uno de los componentes recolectados durante la identificación de los riesgos. Ejemplo: 50% de probabilidad; el impacto: \$ 100.000.000.

En esta etapa debemos listar todos los eventos de riesgo posibles que puedan ocurrir y afectar las actividades normales de nuestra empresa o proyecto. Algunos ejemplos de estos eventos de riesgo podrían ser:

Luego de tener bien definidos todos los eventos probables de riesgos, a los que puede estar sujeta nuestra empresa, debemos continuar asignando dos valores a cada uno con el siguiente criterios:

Para su Probabilidad (donde 1 es Improbable, 2 Posible, 3 Ocasional, 4 Probable y 5 Frecuente):

MATRIZ DE PROBABILIDAD		
Ocurrencia	Significado	Valor
Frecuente	Casi certeza que se produzca	5
Probable	Probable que se produzca	4
Ocasional	Probable que se produzca a veces	3
Posible	Puede ocurrir en algún momento	2
Improbable	Nunca puede ocurrir	1

De la misma forma su impacto (donde 1 sería Insignificante, 2 Menor, 3 Moderado, 4 Peligroso, y 5 Grave) de la siguiente manera:

IMPACTO		
Consecuencia	Significado	Valor
Catastrófico	Crítico, existen importantes errores, severos incumplimientos al Marco Regulatorio que tiene incidencia en el Banco.	5
Peligroso	Errores significativos continuos, existen incumplimientos a los puntos de control internos y disposiciones legales.	4
Moderado	Errores significativos ocasionales, existen incumplimientos a los puntos de control internos y disposiciones legales.	3
Menor	Errores operativos, existen incumplimientos en algunos puntos de control <u>interno</u> pero no constituyen infracciones a la Ley.	2
Insignificante	Errores operativos, existen incumplimientos en algunos puntos de control interno que son subsanables inmediatamente	1

Cálculo del riesgo

Los riesgos se calculan a partir de la relación entre el impacto y probabilidad de ocurrencia, es decir, $\text{riesgo} = \text{impacto} * \text{probabilidad}$

En particular, teniendo en cuenta las calificaciones de impacto y probabilidad presentado anteriormente, al realizar la multiplicación, obtenemos un rango de valores para el riesgo del 0 (sin riesgo) a 25 (muy alto riesgo). Entonces se puede considerar esta propuesta general, por

ejemplo, para el cálculo de los riesgos generales de la organización y proponer las medidas de seguridad adecuadas a su debido tratamiento, teniendo en cuenta, por lo tanto, un nivel aceptable de riesgo, dado que no todos los riesgos debido a los costos, tienen la garantía de ser reducidos por medio de medidas de seguridad.

Por ejemplo si tomamos el riesgo de E - *Catástrofes Naturales*, haremos dos preguntas:

- ¿Qué tan probable es que esto suceda? y asignamos un número 3, pues consideramos que es "Ocasional".
- ¿Qué tanto nos impactaría en caso de suceder? y por ejemplo definimos un 3, ya que su efecto de llegar a suceder, sería "Moderado". Por lo que este riesgo tendría una ponderación de: $3 \times 3 = 9$, ubicamos este Riesgo en la Matriz de acuerdo a las ponderaciones realizadas.

			CONSECUENCIA				
			Insignificante 1	Menor 2	Moderado 3	Peligroso 4	Catastrófico 5
PROBABILIDAD	Frecuente	5					
	Probable	4					
	Ocasional	3			E		
	Posible	2					
	Improbable	1					

El tratamiento de los riesgos de seguridad

Después de la revisión, evaluación y definición de criterios aceptables para los riesgos en la organización, se debe indicar el procedimiento para el tratamiento de los riesgos. Entre las alternativas de tratamiento se destacan:

Evitar: Aplicando medidas de prevención frente a los riesgos, no permitiendo que las vulnerabilidades sean explotadas para la materialización del riesgo

Transferir: los riesgos a terceros mediante contratos con las compañías de seguros, por ejemplo.

Mitigar: Seleccionar y aplicar las medidas de seguridad adecuadas para reducir los riesgos a un nivel aceptable

Aceptar: Se acepta las consecuencias de la posible ocurrencia del riesgo

Recuerde que los riesgos de seguridad varían según la ubicación (escenario o contexto) y, por lo tanto, es importante tener en cuenta este hecho para determinar las medidas de seguridad más adecuadas.

Preste atención al implementar medidas de seguridad, dependiendo de la organización, estas pueden ser no viables. Por ejemplo, la aplicación de registros (*logs*) para todas las actividades del usuario puede ir en contra de la legislación vigente y la privacidad de las personas en su entorno de trabajo.

Es de destacar también que supervisar, evaluar y proponer mejoras regularmente en las medidas de seguridad y, por lo tanto, el tratamiento del riesgo, es bueno para aumentar la eficacia de las prácticas de gestión del riesgo en la organización.

Revisión - Tratamiento de los riesgos de seguridad

» ¿Cuáles son los objetivos del tratamiento del riesgo?

El tratamiento del riesgo es una actividad que se realiza después del análisis/evaluación de riesgos de la organización, con el objetivo de ayudar a reducir los riesgos a un nivel aceptable. Por lo tanto, el uso de procedimientos y medidas de seguridad debe aplicarse en esta actividad, bien sea con medidas preventivas, correctivas o ilustrativas.

Es de destacar que cualquier medida que implica un seguimiento regular de las personas y/o sistemas debe ser implementado de acuerdo con la legislación vigente.

En cuanto al tratamiento de los riesgos de seguridad, algunas áreas se consideran esenciales para la organización para garantizar sus objetivos de negocio. Se destacan entre estas áreas, las preocupaciones como riesgos, impactos y el debido tratamiento para recursos humanos, seguridad de acceso y de comunicaciones, además de los negocios.

- » Seguridad de recursos humanos.
- » Seguridad de acceso.
- » Seguridad de las comunicaciones.
- » Seguridad y negocios.